

Ransomware Infection response

Ransomware · **High** severity · SOC IR Playbook

Incident type	Malware - Ransomware
Severity	High
Priority	Critical (due to potential business impact and data loss)
Detection sources	EDR/XDR, SIEM, User Report, Antivirus, NDR

Scenario

An endpoint or server exhibits signs of ransomware activity such as file encryption, ransom notes or alerts from EDR/XDR tools.

MITRE ATT&CK

T1021.002, T1059, T1486

Preparation

Backup and recovery strategy Periodic offline backups, test restoration Endpoint protection EDR with behavioural detection and rollback features User awareness training Email and USB media handling education Logging coverage Windows logs, Sysmon, file access logs, network flows IOC and threat feed subscriptions Include ransomware-specific indicators

Detection & Analysis

Confirm ransomware activity EDR alert, presence of ransom note, encrypted file extensions Isolate affected host Disconnect from the network or use EDR containment Identify ransomware strain Based on ransom note, file hash or filename pattern Analyse logs and behaviour Track source of execution, lateral movement, suspicious scheduled tasks or services

Containment

Isolate affected systems Block at switch, firewall or via EDR Disable infected accounts Especially if used for lateral movement Block external communication Prevent C2 and key exchange over the internet Snapshot impacted systems For forensic analysis (if required)

Eradication

Remove malware artifacts Delete ransomware files, scripts, scheduled tasks Patch vulnerabilities Address exploited attack vectors such as RDP, SMB, outdated software Perform full antivirus/EDR scan Across all hosts within affected VLAN/subnet Validate removal Ensure no persistence mechanisms remain (registry keys, startup items, services)

Recovery

Restore from clean backup Confirm backups are unaffected before restoration Rebuild systems if needed For systems without clean backups Monitor restored systems Use SIEM and EDR to ensure no reinfection occurs Reset passwords Particularly for privileged and affected users

Lessons Learned & Reporting

Conduct post-incident review Analyse root cause, initial access method and response efficiency Update detection rules Enhance SIEM and EDR correlation rules and triggers Document findings Include indicators, affected systems and timeline Share IOCs Internally and with threat intel communities if allowed

Tools typically involved

SIEM (e.g., Splunk, QRadar, Sentinel); EDR/XDR (e.g., CrowdStrike, Cortex XDR, SentinelOne); Forensics tools (e.g., FTK, Velociraptor, KAPE); Network logs (e.g., Zeek, Suricata, NetFlow); Backup systems (e.g., Veeam,

Rubrik, Commvault)

Success metrics (SLA targets)

Detection Time <10 minutes from encryption onset Isolation Time <15 minutes after detection Recovery Time

Depends on backup availability, ideally <24 hours Containment Scope No lateral movement outside original VLAN

XORCISM SOC Incident-Response Playbook 1 of 42 · PICERL lifecycle · Adapted from the community SOC IR Playbook library
(github.com/okanyildiz/cybersecurity-notes)